

ACEROS AREQUIPA — PLANTA PISCO

Gerencia de Laminación · Trenes 1, 2 y 3

SGIT-CCTV

Sistema de Gestión de Infraestructura Tecnológica y Videovigilancia Industrial

Memoria técnica del proyecto

Análisis del proceso «antes» y «después», modelado UML y BPMN,
arquitectura, seguridad y escalabilidad

Figura 12 — Los seis perfiles: cada uno ve exactamente lo suyo



El reparto se hace SIEMPRE por permiso, nunca por el nombre del rol: un nombre se edita desde la interfaz y la seguridad se cae sola. Un rol con permisos de más no da error — deja pasar en silencio, que es el peor modo de fallar.

Versión 1.0 · Agosto de 2026

Documento de trabajo interno

Índice

Para actualizar el índice en Word: pulsa dentro de él y luego F9.

1. Resumen ejecutivo

La planta de Pisco tiene cámaras, grabadores, switches, tableros y enlaces inalámbricos repartidos por tres trenes de laminación. Hasta ahora esa infraestructura no estaba en ninguna parte: ni un inventario fiable, ni un historial de averías, ni una forma de saber qué se cae si se apaga un equipo concreto. Cuando una cámara dejaba de ver, el aviso viajaba por radio, la reparación se anotaba en un cuaderno y el indicador mensual se tecleaba a mano en una hoja de cálculo.

SGIT-CCTV convierte ese proceso en un sistema. No es un inventario más: es un ERP de mantenimiento acotado a la infraestructura de videovigilancia y red de LAMINACIÓN, construido sobre tres ideas que se explican a lo largo de este documento.

1) El árbol de planta manda: el tren, la etapa, el ambiente, la criticidad y el intervalo preventivo de un equipo se deducen de DÓNDE cuelga, no se escriben a mano.

2) Lo que se puede calcular no se guarda: el grafo de red se arma en cada consulta y el estado efectivo de un activo se deriva. Guardar una copia significa mantener dos verdades, y la segunda siempre se queda vieja.

3) Sin pantalla, no existe: un modelo de datos y un endpoint no son una funcionalidad. Si el usuario no tiene una puerta de entrada, esa capacidad no está construida.

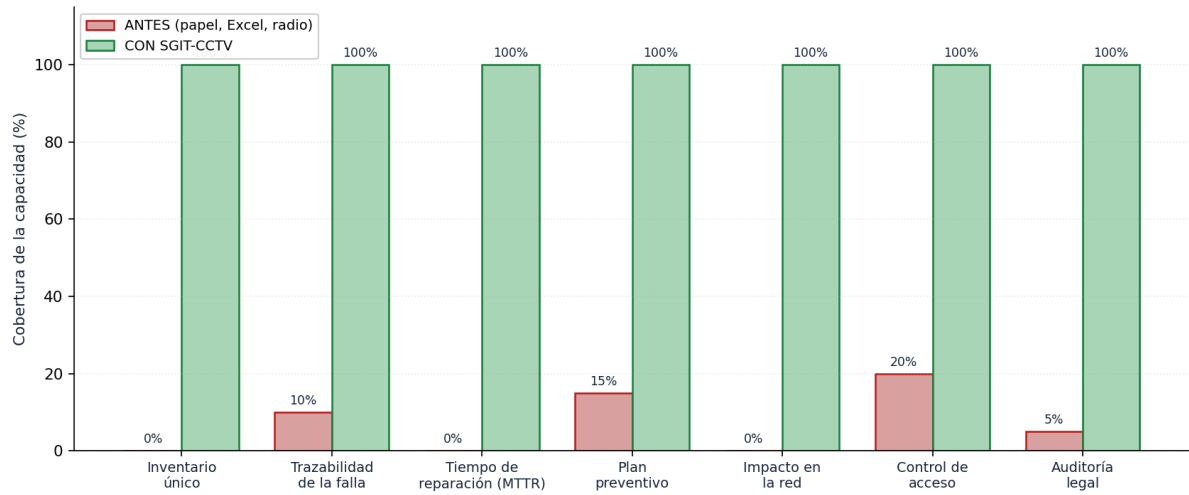
1.1 Qué hay construido hoy

Métrica	Valor	Métrica	Valor
Módulos de backend	40	Pantallas de usuario	52
Endpoints REST	334	Componentes de interfaz	44
Modelos de datos	73	Enumerados de dominio	54
Migraciones de base de datos	42	Permisos del catálogo	44
Líneas de backend	36.070	Líneas de frontend	26.799
Pruebas automatizadas	937	Verificadores propios	23

Los 23 «verificadores» merecen una explicación, porque no son pruebas al uso. Cada uno nació de un fallo real que llegó a producción o a la máquina del usuario, y su trabajo es impedir que ese fallo concreto vuelva a pasar. Se ejecutan antes de cada entrega y en la integración continua. La sección 9 los detalla.

1.2 Qué cambia para la planta

Figura 10 — Capacidades de gestión antes y después del sistema



Escala: 0 % = el dato no existe en ninguna parte · 100 % = el sistema lo registra y lo deriva solo.

Figura 10 — Capacidades de gestión antes y después del sistema.

Las cifras de la izquierda no son estimaciones pesimistas: son zeros literales. Antes del sistema no existía un inventario único, no existía el tiempo medio de reparación y no existía forma de saber qué cámaras dependen de un switch. No es que se midiera mal; es que no se medía.

2. El problema: cómo se trabajaba antes

Esta sección describe el proceso real, no una versión idealizada. Se ha reconstruido a partir de lo que ocurre hoy en planta, y es el punto de comparación de todo lo que viene después.

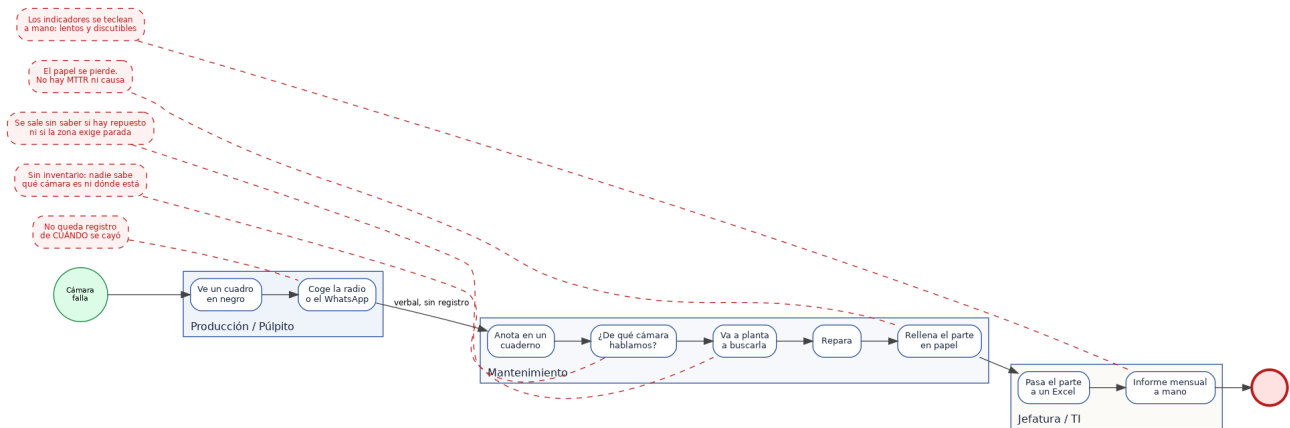


Figura 6 — BPMN «COMO ESTÁ» (AS-IS): el proceso antes del sistema

Figura 6 — Proceso «COMO ESTÁ» (AS-IS), modelado en BPMN 2.0 con carriles por responsable. Los recuadros rojos son los puntos de dolor.

2.1 Los cinco puntos de dolor

a) El aviso viaja de boca y no deja rastro

Producción ve un cuadro en negro y lo dice por radio o por WhatsApp. Funciona para que alguien se entere, pero no queda registro de la hora exacta en que la cámara dejó de ver. Sin esa hora no hay tiempo de indisponibilidad, y sin tiempo de indisponibilidad no hay forma honesta de decir si el servicio está mejorando o empeorando.

b) Nadie sabe de qué cámara se está hablando

Sin inventario ni rotulado normalizado, la conversación empieza por «la del horno» o «la que está cerca de la cizalla». El técnico sale a planta a identificar el equipo antes de poder repararlo. Ese viaje de reconocimiento es tiempo perdido que nadie contabiliza.

c) Se sale a planta sin la información que evita el segundo viaje

Hay tres datos que cambian por completo la salida y que antes no estaban en ninguna parte: si hay repuesto en almacén, cómo se llega físicamente al equipo (escalera, plataforma elevadora, altura) y —el más grave— si la zona permite trabajar con el tren en marcha o exige que la línea esté parada. Sin ellos se sale a ciegas.

d) El parte en papel se pierde, y con él la causa

El técnico rellena un parte a mano. Ese papel puede perderse, y aunque no se pierda, la causa está escrita en texto libre. Con texto libre no se puede contar después qué falla más: «óptica sucia», «lente sucio» y «suciedad en el domo» son la misma avería escrita de tres maneras, y ninguna estadística las agrupa.

e) Los indicadores se teclean a mano

El informe mensual sale de pasar los partes a una hoja de cálculo. Es lento, y sobre todo es discutible: cuando un número se ha tecleado a mano, cualquiera en una reunión puede poner en duda de dónde salió, y normalmente tiene razón.

2.2 El coste de no medir

La literatura de mantenimiento industrial coincide en el orden de magnitud del problema. El programa federal de gestión energética del Departamento de Energía de Estados Unidos sitúa entre un 25 % y un 30 % la reducción de

paradas no planificadas al sustituir un mantenimiento puramente reactivo por un sistema de gestión de mantenimiento asistido por ordenador. Los estudios de industria 4.0 de McKinsey documentan mejoras de disponibilidad de entre el 20 % y el 50 % cuando ese sistema se combina con sensórica. Y en tiempo de reparación, la comparación entre flujo en papel y flujo digital arroja reducciones en torno al 40 %.

Estas cifras se citan como referencia del sector, NO como promesa de resultado en Pisco. El sistema no puede prometer una mejora que todavía no ha medido: precisamente el primer valor que aporta es empezar a medir. Lo que sí se puede afirmar sin margen de duda es que hoy esos indicadores no existen.

3. La solución: el proceso con el sistema

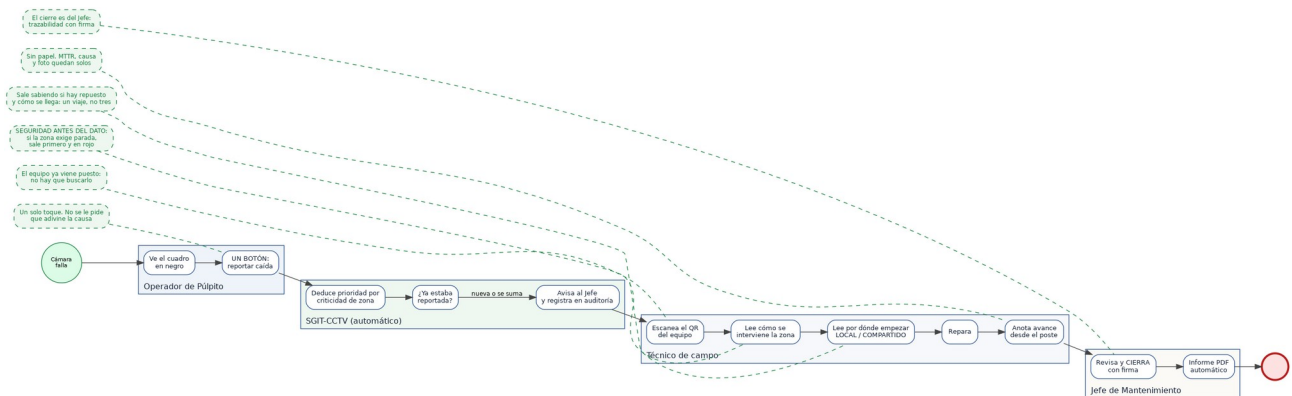


Figura 7 — BPMN «COMO SERÁ» (TO-BE): el proceso con SGIT-CCTV

Figura 7 — Proceso «COMO SERÁ» (TO-BE) en BPMN 2.0. Los recuadros verdes señalan qué resuelve cada paso.

3.1 El cambio de fondo

El proceso nuevo no añade burocracia: quita pasos. Producción pasa de describir una avería por radio a pulsar un botón. El técnico pasa de buscar el equipo a escanear la etiqueta que tiene delante. Y el Jefe de Mantenimiento pasa de teclear un Excel a firmar un cierre que genera el informe solo.

3.2 Los tres principios de diseño que lo sostienen

Principio 1 — Nunca se le pide a alguien un dato que no puede saber

Es la decisión de diseño más importante del sistema y la que más veces se ha aplicado. El operador de púlpito mira un monitor y sabe una sola cosa: que no está viendo. Pedirle que clasifique si la avería es de la fuente de alimentación, del cable o del grabador es pedirle que adivine, y una categoría adivinada ensucia para siempre la estadística de qué falla más. Por eso su formulario es un botón, y el catálogo detallado de causas es del técnico, que está delante del equipo con la tapa abierta.

Principio 2 — Falla hacia el lado seguro

Cuando el sistema no sabe algo, se comporta como si la situación fuera la más restrictiva. Si nadie ha firmado cómo se interviene una zona, el sistema pide que el tren esté parado. Si la ficha del equipo no trae ese dato por un fallo de red, también. Un error del sistema puede hacer esperar a alguien; nunca puede hacer que alguien suba a una zona caliente creyendo que puede.

Principio 3 — Lo que el sistema registra, se dice por delante

Cada avance que anota un técnico queda con su nombre y la hora, y pasa por auditoría. Eso se le dice en pantalla ANTES de que pulse, no después. Un sistema que audita en silencio se siente como una trampa y la gente deja de usarlo; uno que lo avisa por delante se usa con confianza.

3.3 Recorrido completo de una avería

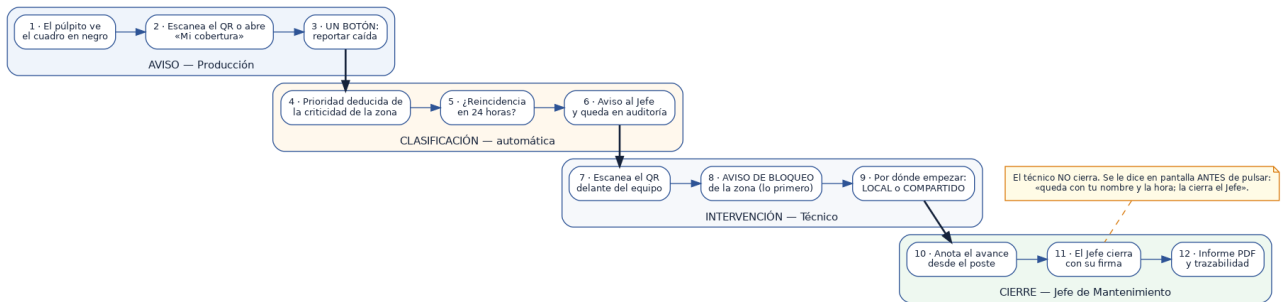


Figura 3 — Del cuadro en negro a la orden firmada: las doce etapas

Figura 3 — Las doce etapas, del cuadro en negro a la orden firmada.

Conviene detenerse en la etapa 8. El sistema calcula desde hace meses si una zona se puede tocar con el tren produciendo, con permiso eléctrico, con permiso de altura, o si exige parada. Ese dato lo firma una persona con nombre y fecha. Y durante un tiempo se calculó sin enseñarse: el técnico escaneaba el código de la cámara y la pantalla le contaba la marca, el modelo y la dirección IP, pero no que ahí abajo pasa barra caliente. Era el error del principio 3 aplicado a una advertencia de seguridad, y por eso ahora ese aviso va por encima de todo lo demás en la pantalla.

4. Modelado del sistema

4.1 Actores y casos de uso

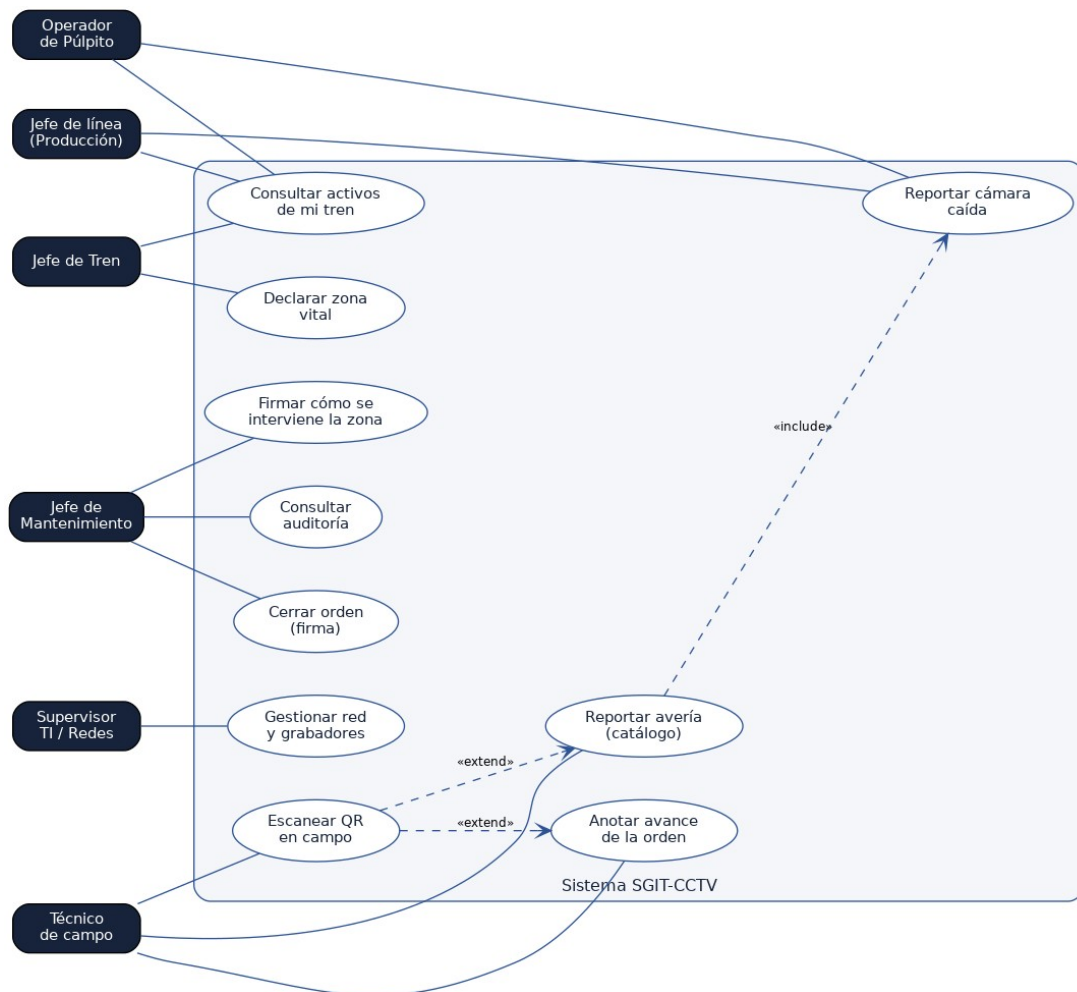


Figura 1 — Diagrama de casos de uso · SGIT-CCTV (UML 2.5)

Figura 1 — Diagrama de casos de uso (UML 2.5). Seis actores; cada uno ve exactamente lo suyo.

Los actores no son categorías abstractas: son los seis puestos que existen en la planta. La diferencia entre ellos no se decide por su nombre sino por lo que pueden hacer, y esa distinción es el eje de la sección 6.

4.2 Modelo de dominio

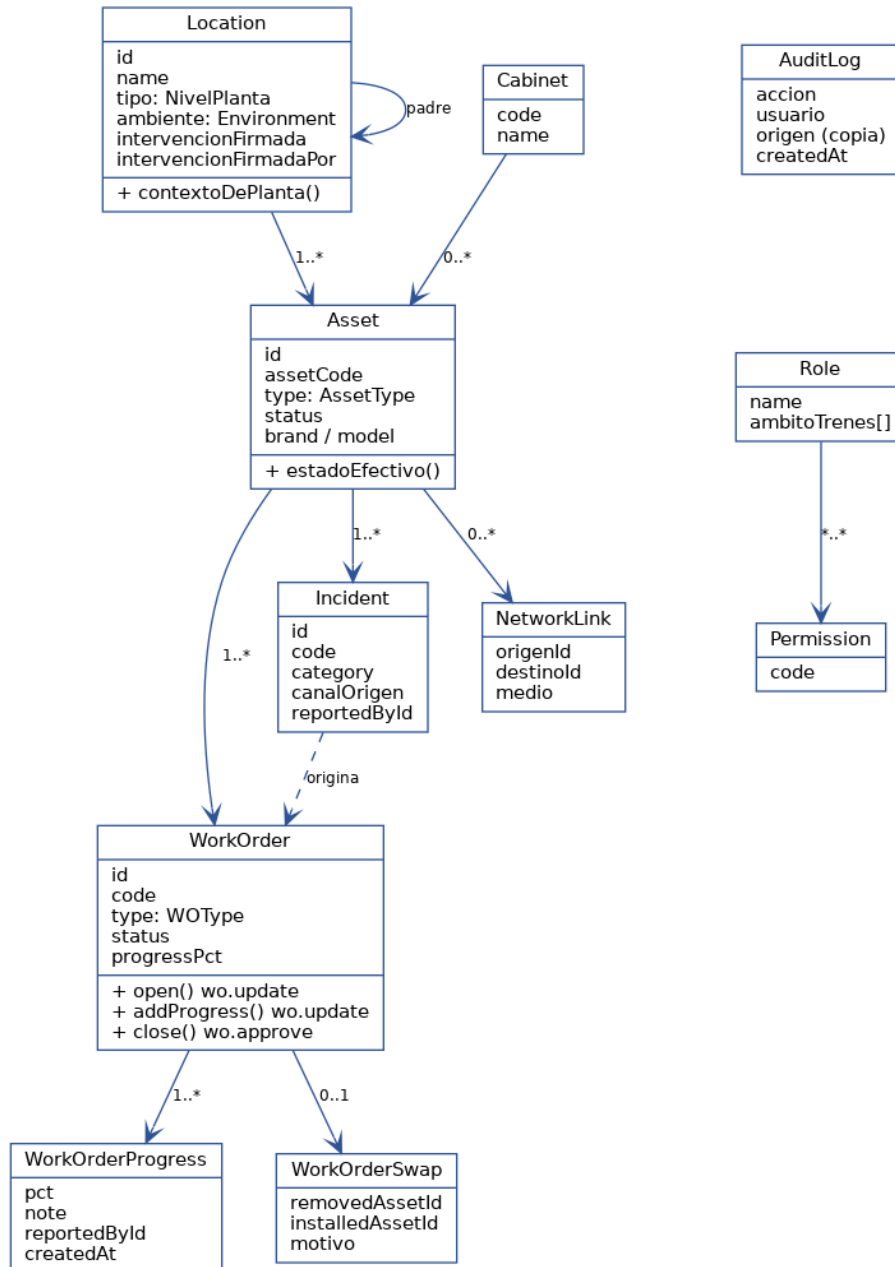


Figura 2 — Diagrama de clases del dominio (extracto de 73 modelos)

Figura 2 — Diagrama de clases (extracto de los 73 modelos del sistema).

La ubicación como columna vertebral

La clase Location se relaciona consigo misma: es un árbol. Planta → Laminación → Tren → Etapa → Zona → Gabinete → Equipo. De esa jerarquía el sistema deduce, para cada activo, el tren al que pertenece, la etapa del proceso, el ambiente al que está sometido, su criticidad efectiva y cada cuántos días toca mantenimiento preventivo.

Escribir el tren directamente en el activo fue un error que hubo que deshacer. Cuando un dato se puede deducir de la estructura y además se copia en el registro, el día que alguien corrige la estructura queda una copia vieja que nadie sabe que existe.

El estado no se guarda, se deriva

El estado efectivo de un equipo se calcula a partir de sus incidencias abiertas y sus órdenes en curso. Lo mismo ocurre con el grafo de red: se arma en cada consulta a partir de los enlaces declarados. Es más trabajo de cálculo, y a cambio no hay nunca dos versiones de la verdad.

4.3 Arquitectura por capas



Figura 5 — Arquitectura por capas y módulos (40 módulos, 334 endpoints)

Figura 5 — Capas y módulos. La lógica de dominio es código puro, sin base de datos, y por eso se puede probar aparte.

La capa de dominio es la parte del sistema que contiene las decisiones de planta —cómo se calcula la criticidad, si una zona exige parada, por dónde empezar un diagnóstico, si una avería es reincidente— y está escrita como funciones puras: reciben datos y devuelven datos, sin tocar la base. Eso permite probarla exhaustivamente y explicarla en una reunión sin abrir un servidor.

4.4 Despliegue

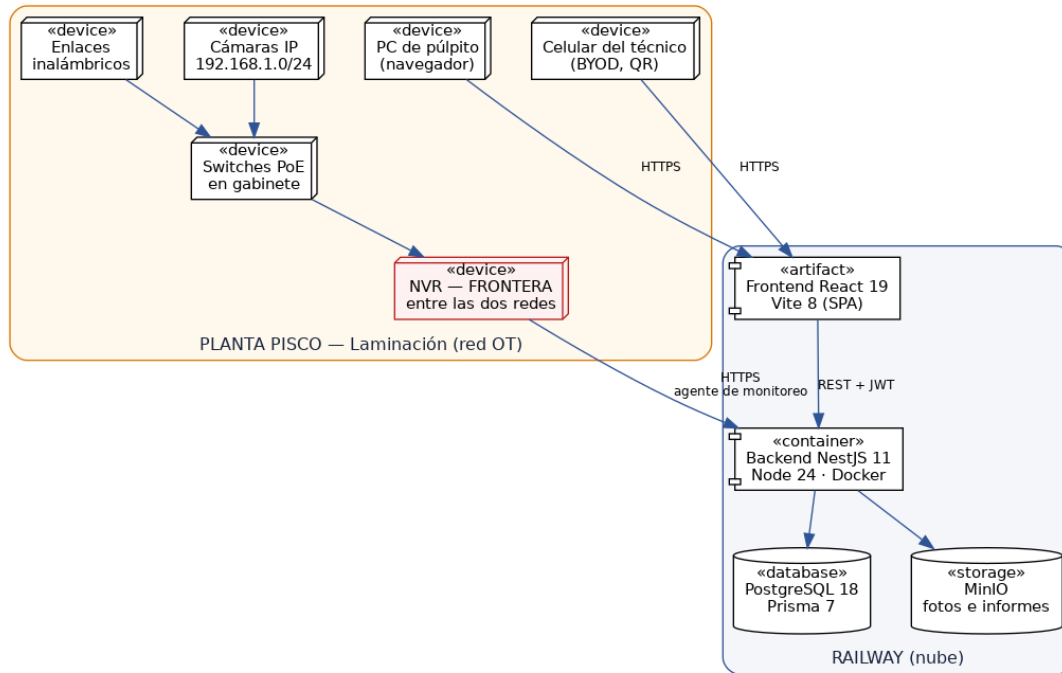


Figura 4 — Diagrama de despliegue (UML) · producción en Railway

Figura 4 — Diagrama de despliegue. El grabador es la frontera entre la red de cámaras y la red corporativa.

El técnico usa su propio teléfono. Es una decisión consciente: obligar a la cuadrilla a llevar un terminal adicional garantiza que el terminal se queda en el taller. A cambio, el sistema no guarda nada sensible en el dispositivo, la sesión caduca y los permisos se comprueban en el servidor en cada petición.

5. Seguridad

Esta sección es la que más importa a la hora de decidir si el sistema puede vivir conectado a la red de planta. Se divide en tres frentes: la red, las credenciales y el control de acceso.

5.1 El problema de la red plana

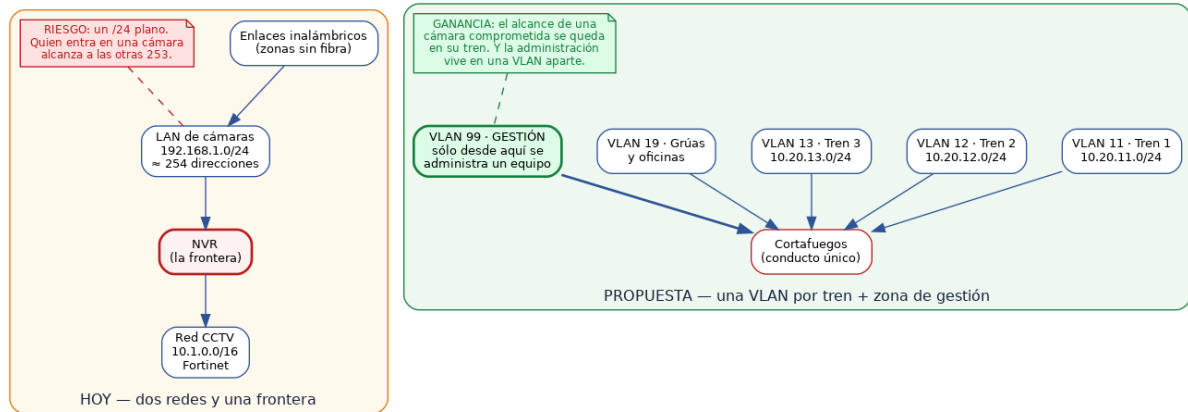


Figura 8 — Segmentación de red: situación actual y propuesta (zonas y conductos, IEC 62443)

Figura 8 — Segmentación actual y propuesta, siguiendo el modelo de zonas y conductos de la norma IEC 62443.

Hoy las cámaras viven en un único segmento 192.168.1.0/24. Todas se ven entre sí. La norma IEC 62443 —el estándar internacional de ciberseguridad para sistemas de automatización industrial— organiza este problema en «zonas» (grupos de equipos con requisitos de seguridad parecidos) y «conductos» (los caminos controlados por los que se comunican). Un segmento plano es una única zona enorme: el radio de daño de cualquier intrusión es el total.

Propuesta: una VLAN por tren y una zona de gestión

La propuesta no es exótica ni cara: separar cada tren en su propia red y crear una red de gestión desde la cual —y sólo desde la cual— se administran los equipos. El beneficio es directo: una cámara comprometida en el Tren 1 no alcanza a las del Tren 3, y la administración de los equipos deja de estar accesible desde el mismo sitio donde circula el vídeo.

Y de paso resuelve un problema de crecimiento

Un /24 son 254 direcciones. Con las cámaras actuales, los grabadores, los switches, los enlaces inalámbricos y los equipos de púlpito, ese espacio se agota antes de lo que parece. Segmentar por tren multiplica el espacio disponible y, sobre todo, lo hace previsible: al ver una dirección se sabe de qué tren es.

5.2 Las credenciales de los enlaces inalámbricos

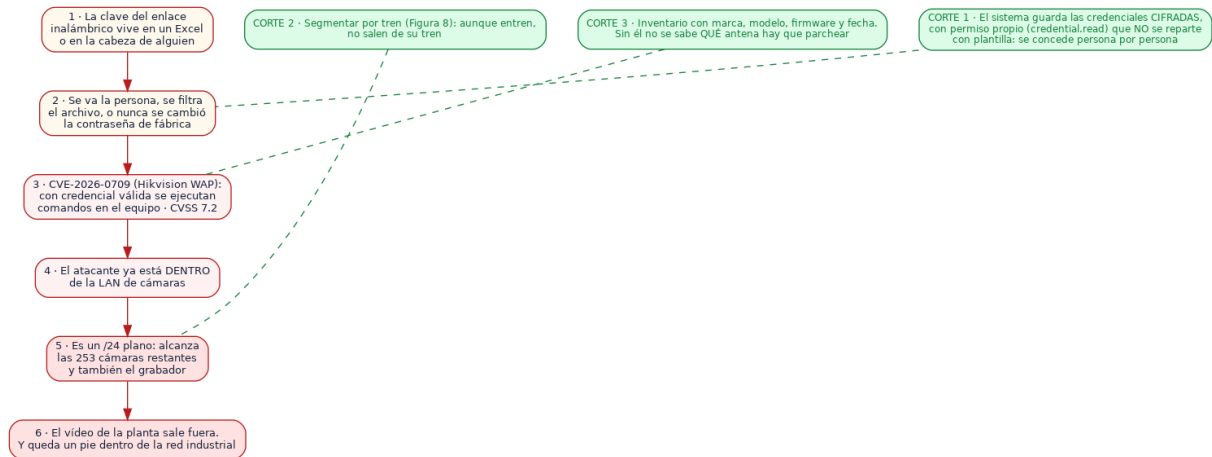


Figura 9 — Por qué una credencial perdida en una antena es un problema de planta, no de TI

Figura 9 — Cadena de ataque a partir de una credencial filtrada, y los tres puntos donde el sistema la corta.

Este punto merece una explicación cuidadosa porque suele subestimarse. La contraseña de un enlace inalámbrico o de una cámara parece un dato menor —«total, es una cámara»— y no lo es.

El caso concreto: CVE-2026-0709

En 2026 se publicó una vulnerabilidad en los puntos de acceso inalámbricos de Hikvision, catalogada como CVE-2026-0709, con una puntuación de severidad de 7,2 sobre 10. La vulnerabilidad permite ejecutar comandos arbitrarios en el equipo enviando paquetes especialmente contruidos. El detalle que la hace relevante aquí es su requisito previo: el atacante necesita una credencial válida. Y una credencial válida se obtiene de tres formas —un archivo que se filtra, una persona que se va, o un equipo que nunca cambió la contraseña de fábrica—.

A partir de ahí la cadena se encadena sola: con comandos en la antena se está dentro de la red de cámaras; en una red plana eso significa acceso al resto de cámaras y al grabador; y con el grabador se tiene el vídeo de la planta y un punto de apoyo dentro de la red industrial.

Los tres cortes que introduce el sistema

Corte	Qué hace	Por qué funciona
1 · Credenciales cifradas y con permiso propio	Las contraseñas de los equipos se guardan cifradas. Verlas exige el permiso credential.read, que NO se reparte con las plantillas de rol: se concede a mano, persona por persona, después de crear el rol.	Una plantilla se pulsa sin leer. Un permiso concedido a mano obliga a una decisión consciente que además queda en la auditoría.
2 · Inventario con firmware y fecha	Cada antena, cámara y switch está registrado con marca, modelo, versión de firmware y fecha de instalación.	Cuando se publica una vulnerabilidad, la primera pregunta es «¿cuántos equipos afectados tengo y dónde están?». Sin inventario esa pregunta no tiene respuesta y el parcheo nunca se completa.
3 · Segmentación por tren	La propuesta de la sección 5.1.	Aunque un atacante entre, no sale de su tren. Es defensa en profundidad: se asume que la primera barrera puede fallar.

5.3 Control de acceso

Figura 12 — Los seis perfiles: cada uno ve exactamente lo suyo



El reparto se hace SIEMPRE por permiso, nunca por el nombre del rol: un nombre se edita desde la interfaz y la seguridad se cae sola. Un rol con permisos de más no da error — deja pasar en silencio, que es el peor modo de fallar.

Figura 12 — Los seis perfiles del sistema, del más amplio al más estrecho.

La regla que costó un incidente aprender

El control de acceso se decide SIEMPRE por permiso y NUNCA por el nombre del rol. La razón se aprendió con un fallo real que llegó a producción.

Existían dos roles para el mismo puesto: «Jefe de Producción», creado por la semilla del sistema, y «Jefe de línea (Producción)», creado desde las plantillas de la interfaz. Nadie lo notó porque ambos funcionaban. Cuando se escribió una migración para cerrar un agujero de permisos, la migración identificaba los roles comparando contra el nombre escrito a mano y excluía a «Jefe de Producción». El usuario real tenía el otro rol. Resultado: la migración escrita para CERRAR el agujero fue la que se lo abrió, y Producción pasó a ver el plano eléctrico y el direccionamiento IP de toda la planta.

El nombre de un rol se edita desde la interfaz: es un dato de usuario. Y cuando no coincide, el SQL no falla — simplemente no hace nada. Falla ABRIENDO, que es el peor modo de fallar, porque no deja rastro.

La corrección reparte los permisos comprobando qué puede hacer ya cada rol: conserva el acceso a infraestructura sólo en los perfiles que ya pueden crear, editar o borrar activos. No contiene ni un solo nombre de rol. Y se añadió un verificador automático que impide que ninguna migración futura vuelva a comparar por nombre.

Cuatro guardas en cadena

Cada petición al servidor atraviesa cuatro comprobaciones, en este orden: límite de peticiones por minuto, validez de la sesión, permiso requerido por el endpoint y, la última, ámbito de tren. El orden no es casual: preguntar «¿es de tu tren?» antes de saber quién eres es trabajo tirado.

El ámbito por tren, y las tres reglas que evitan romper trabajo legítimo

Un usuario asignado al Tren 2 no puede consultar el equipo del Tren 1 aunque conozca su identificador. Esto se implementó con tres cautelas deliberadas, porque cerrar de más se nota tarde —cuando alguien está en planta y no puede abrir su orden—:

1. Ámbito vacío significa todos los trenes. Hoy todos lo tienen vacío, así que la medida no cambió el comportamiento de nadie al desplegarse.
2. Un registro sin ubicación pasa. Los repuestos en almacén y el mapeo sin equipo asignado no tienen tren, y bloquearlos dejaría el almacén invisible.
3. Si la comprobación falla por un error interno, pasa. Es una capa de defensa en profundidad, no la única: este control no puede tumbar el sistema.

Y se responde 404, no 403. Un 403 confirma que el registro existe, y con eso se pueden recorrer identificadores y dibujar el inventario del vecino sin leer un solo campo.

6. El código: cómo se traducen las reglas de planta

Esta sección muestra fragmentos reales del sistema. No están puestos para demostrar volumen, sino porque cada uno resuelve una regla de planta concreta y se entiende sin ser programador.

6.1 Falla hacia el lado seguro: la intervención de una zona

El sistema propone cómo se puede intervenir una zona a partir del ambiente al que está sometida. Pero una propuesta no autoriza a nadie a acercarse a la línea: hasta que una persona no firma, el sistema aplica «exige parada».

backend/src/common/intervenibilidad.ts

```
export function resolver(propuesta, firmada) {
  if (!firmada) {
    return {
      aplica: 'EXIGE_PARADA',      // <- sin firma, lo más restrictivo
      estaFirmada: false,
      motivo: `El sistema propondría «${ETIQUETA[propuesta]}», pero nadie lo`
        + ` ha firmado todavía. Una propuesta no autoriza a nadie a`
        + ` acercarse a la línea.`
    };
  }
  // Si la firma permite MÁS de lo que hoy tocaría, se avisa: el ambiente
  // de la zona cambió después de firmar.
  const desactualizada = ORDEN[firmada] < ORDEN[propuesta];
  return { aplica: firmada, estaFirmada: true, firmaDesactualizada: desactualizada, ... };
}
```

Y en la pantalla, el mismo principio se repite: si por cualquier motivo la ficha no trae ese dato, se pinta el caso más restrictivo en lugar de callarse.

frontend/src/components/AvisoDelIntervencion.tsx

```
// Si la ficha no trae el dato, NO se calla: se pinta el caso más
// restrictivo. Un fallo de red no puede convertirse en silencio delante
// de una línea caliente.
const nivel = planta?.intervencionAplica || 'SIN_CLASIFICAR';
```

6.2 Quién puede cerrar una orden

El técnico ejecuta el trabajo y anota el avance; el cierre lleva firma y lo hace el Jefe de Mantenimiento. Son dos permisos distintos declarados en el propio endpoint.

backend/src/modules/maintenance/maintenance.controller.ts

```
@AmbitoDe('workOrder')
@Post(':id/progress')
@RequirePermissions('wo.update') // <- el técnico
progress(@Param('id') id, @Body() dto, @CurrentUser() user, @Ip() ip) {
  return this.wo.addProgress(id, dto, user?.userId, ip);
}

// Cierre firmado: SOLO Jefe de Mantenimiento
@AmbitoDe('workOrder')
@Post(':id/close')
@RequirePermissions('wo.approve') // <- sólo el Jefe
close(@Param('id') id, @Body() dto, @Ip() ip) {
  return this.wo.closeSigned(id, dto, ip);
}
```

6.3 La deducción del diagnóstico

Cuando se cae una cámara, la primera pregunta útil es si el problema es de ese equipo o de algo del que cuelgan varios. El sistema lo deduce mirando el estado de los equipos vecinos, y traduce el resultado a una instrucción concreta.

`backend/src/modules/network/arranque-de-diagnostico.ts`

```
const caidos = e.vecinos.filter((v) => CAIDO.includes(v.estado));

if (caidos.length === 0) {
  return { veredicto: 'LOCAL', ... }; // sólo se cayó éste
}
if (caidos.length === e.vecinos.length) {
  return { veredicto: 'COMPARTIDO', ... }; // se cayeron todos
}
// Algunos sí y otros no: decir «es local» sería adivinar.
return { veredicto: 'SIN_DETERMINAR', ... };
```

Y la instrucción que se le da al técnico en el caso LOCAL manda empezar por la alimentación, no por el cable: la corriente se comprueba en un minuto desde el gabinete, mientras que revisar el cable exige subir.

Mismo archivo — sin siglas, a propósito

```
const base = 'Empieza por la CORRIENTE de este equipo: si sólo se cayó él '
+ 'y los de al lado siguen viendo, lo más probable es que se haya '
+ 'quedado sin alimentación por el cable de red (el puerto o la fuente '
+ 'que lo energiza). Si tiene corriente, sigue por su tramo de cable.';
```

Una prueba automática prohíbe la jerga de redes en estos textos —incluida la sigla «PoE»— porque los lee quien está delante del equipo, no un ingeniero de redes. La primera versión de este mensaje decía «ha perdido el PoE» y la prueba la tumbó.

6.4 El reparto de permisos por capacidad, nunca por nombre

Ésta es la corrección del incidente descrito en la sección 5.3, escrita como una migración de base de datos. No contiene ni un solo nombre de rol.

`20260902000000_reparto_infra_red_por_capacidad/migration.sql`

```
DELETE FROM "role_permissions" rp
USING "permissions" p
WHERE rp."permissionId" = p."id"
AND p."code" IN ('infra.read', 'red.read')
-- Se conserva sólo si el rol tiene ALGUNA capacidad de escritura
-- sobre la infraestructura. NOT EXISTS = «este rol sólo mira».
AND NOT EXISTS (
  SELECT 1 FROM "role_permissions" rp2
  JOIN "permissions" p2 ON p2."id" = rp2."permissionId"
  WHERE rp2."roleId" = rp."roleId"
  AND p2."code" IN ('asset.create', 'asset.update',
    'asset.delete', 'location.manage')
);
```

6.5 El perfil más estrecho: Operador de Pulpito

Tres permisos y ninguno más. Cada permiso que NO tiene está justificado en el propio código, porque las decisiones que no se explican se deshacen sin querer seis meses después.

`backend/src/modules/roles/catalogo-permisos.ts`

```
{
  nombre: 'Operador de Pulpito',
  paraQuien: 'Quien está delante del monitor en el pulpito del Tren 1, 2 o 3.',
  descripcion:
    'Ve las cámaras de SU tren y avisa cuando una deja de dar imagen. ' +
    'Nada más: ni indicadores, ni órdenes, ni declarar zonas.'
```

```
necesitaAmbito: true,  
permisos: [  
  'activos.mirar',           // las cámaras de su tren  
  'incident.create', 'incident.read', // avisar, y ver si ya está avisado  
],  
}
```

7. Pruebas y verificación

El sistema tiene 937 pruebas automatizadas y 23 verificadores propios. La diferencia entre ambos importa: una prueba comprueba que el sistema hace lo que debe; un verificador comprueba que el CÓDIGO no ha vuelto a cometer un error concreto que ya se cometió una vez.

7.1 Los verificadores, y por qué existen

Cada verificador nació de un fallo real. Estos son los más significativos:

Verificador	Qué caza	De dónde salió
verificar:inyeccion	Una clase inyectada que no está declarada en su módulo	Caída de producción: faltó declarar un servicio y el sistema no arrancó
verificar:campos	Un campo que no existe dentro de una consulta a la base	Un campo inexistente invalida el tipo del resultado entero y TypeScript acaba señalando media docena de sitios correctos
verificar:migraciones	Desfase entre el esquema y las migraciones, sin necesidad de base de datos	Desfase repetido en la integración continua
verificar:ambito	Una ruta con identificador que no declara su ámbito de tren	Un decorador que hay que acordarse de poner es un agujero con fecha
verificar:sql-roles	Una migración que reparte permisos comparando el nombre del rol	El incidente de la sección 5.3
verificar:coherencia	Un rol de sólo observación que lleva permisos de operación	Producción con acceso a módulos de mantenimiento
verificar:etiquetas	Un campo de formulario sin etiqueta que lo envuelva	Con guantes, que tocar el texto enfoque el campo es la diferencia entre escribir la nota y no escribirla
verificar:formato	Errores de sintaxis en el frontend, usando el mismo analizador que el compilador	Un error de sintaxis llegó a la máquina del usuario tras 19 archivos escritos

La regla de oro al escribir un verificador

Se prueba SIEMPRE contra el código real antes de darlo por bueno, y se comprueba que caza el error para el que se hizo, reintroduciéndolo a propósito. Un verificador que se equivoca es peor que no tenerlo: enseña al equipo a ignorarlo.

Cuatro de los verificadores dieron falsos positivos en su primera versión. Uno de ellos, el de sintaxis, marcó cinco archivos correctos porque contaba comillas por línea; la versión buena no adivina: le pasa cada archivo al mismo analizador que usa el compilador. Otro, el de nombres de rol en SQL, acusó de inexistente al rol de administrador porque su lista de permisos estaba escrita de una forma que la expresión regular no contemplaba.

7.2 Pruebas de seguridad

Las pruebas de control de acceso comprueban SIEMPRE las dos direcciones: que el usuario legítimo pasa y que el ajeno no. Sólo con la primera se puede tener un guarda que deja pasar todo; sólo con la segunda, uno que no deja pasar a nadie.

`backend/test/qr-en-campo.spec.ts`

```
it('CERRAR LA ORDEN sigue siendo SOLO del Jefe de Mantenimiento', () => {
  expect(permisoDe(ctrl, 'close')).toBe('wo.approve');
```

```
expect(permisoDe(ctrl, 'close')).not.toBe('wo.update');
});

it('TODO avance guarda quién lo escribió y pasa por auditoría', () => {
  const cuerpo = svc.slice(svc.indexOf('async addProgress'), +8000);
  expect(cuerpo).toContain('reportedById');
  expect(cuerpo).toContain('this.audit.record');
});
```

Estas pruebas leen el CÓDIGO, no el comportamiento. El motivo es concreto: el fallo típico no es escribir mal un permiso, es quitarlo «un momento para probar» y olvidarse de volver a ponerlo. Se validaron aflojando el cierre a propósito para comprobar que se caen.

7.3 Hallazgos abiertos de la auditoría de seguridad

El documento sería deshonesto si sólo listara lo resuelto. Éstos siguen abiertos:

Ref.	Hallazgo	Estado
S-01	Rotación del secreto de firma de sesiones. Con ese secreto se puede firmar un token con permisos de administrador sin usuario ni contraseña.	Abierto — prioridad máxima
S-03	Sin límite de peticiones en algunos módulos. La exportación completa genera el libro en memoria.	Abierto
S-04	Al desactivar un usuario, su sesión sigue viva hasta 15 minutos. Procedimiento correcto hoy: desactivar Y cerrar todas sus sesiones.	Conocido y documentado
S-05	Endpoints que aceptan el cuerpo de la petición sin clase de validación.	Abierto
S-06	La integración continua no revisa las dependencias de terceros.	Abierto
S-07	Falta política de contenido en el navegador (CSP).	Abierto

Y la deuda técnica reconocida: la restauración del respaldo de la base de datos nunca se ha probado. Un respaldo que no se ha restaurado es una hipótesis, no un respaldo.

8. Tecnologías utilizadas y por qué

En agosto de 2026 se completó una migración de toda la pila a versiones actuales. No fue un capricho: el proyecto arrastraba componentes con avisos de seguridad y con soporte terminado, y en un sistema expuesto a la red eso es una deuda que se paga sola en el peor momento.

Componente	Versión	Para qué se usa y qué aporta
Node.js	24.14 LTS	Entorno de ejecución. Versión con soporte activo hasta abril de 2028. Se venía de la 22, que entró en mantenimiento —sólo parches críticos— en octubre de 2025.
TypeScript	5.9	Tipado estático. Detecta en la compilación errores que de otro modo aparecen en planta: un campo mal escrito, un valor que puede ser nulo.
NestJS	11.2	Estructura del servidor. Su sistema de módulos e inyección de dependencias es lo que permite que el control de acceso sea una cadena de guardas y no un «if» repetido en 334 sitios.
Prisma	7.9	Acceso a la base de datos con tipos generados a partir del esquema. La versión 7 elimina el motor escrito en Rust, lo que reduce el tamaño de la imagen y los problemas de compatibilidad con Alpine Linux.
PostgreSQL	18	Base de datos. Se eligió por su integridad referencial: las cascadas de borrado las hace la base, no el código, porque una relación añadida más adelante se olvidaría de programar.
React	19.2	Interfaz. Carga diferida por ruta, de modo que el púlpito no descarga las 52 pantallas para usar una.
React Router	7.18	Navegación de la aplicación de página única.
Vite	8.2 (rolldown)	Empaquetado. El cambio a rolldown reduce sensiblemente el tiempo de construcción.
ESLint	10.9	Análisis estático del frontend. La versión anterior llevaba 22 meses sin soporte.
argon2	0.45	Cifrado de contraseñas. Es el algoritmo recomendado actualmente, por delante de bcrypt.
Docker	—	Empaquetado del servidor. Imagen en dos etapas: se compila en una y se ejecuta en otra sin el compilador ni las dependencias de desarrollo, y nunca como usuario administrador.
Railway	—	Despliegue continuo desde el repositorio. Cada cambio aprobado se publica solo.
MinIO	—	Almacenamiento de fotografías e informes, compatible con S3.

8.1 Resultado de la actualización

- El frontend pasó de 4 vulnerabilidades conocidas a CERO.
- El backend pasó de 12 a 5, y las 5 restantes se trazaron individualmente hasta comprobar que no son alcanzables desde ninguna ruta expuesta.
- Ninguna pérdida de datos y ninguna interrupción permanente del servicio: durante los despliegues fallidos la versión anterior siguió atendiendo.

8.2 Una decisión técnica que conviene explicar

La documentación oficial de Prisma 7 recomienda convertir el proyecto a módulos ECMAScript. NestJS 11 no soporta oficialmente ese formato. La migración fue posible gracias a una única línea de configuración que mantiene el formato anterior, y esa línea evitó reescribir la aplicación entera. Está documentada en el propio esquema para que nadie la borre pensando que sobra.

9. Hasta dónde puede escalar el sistema

Figura 11 — Hasta dónde escala el sistema, y qué hace falta en cada salto

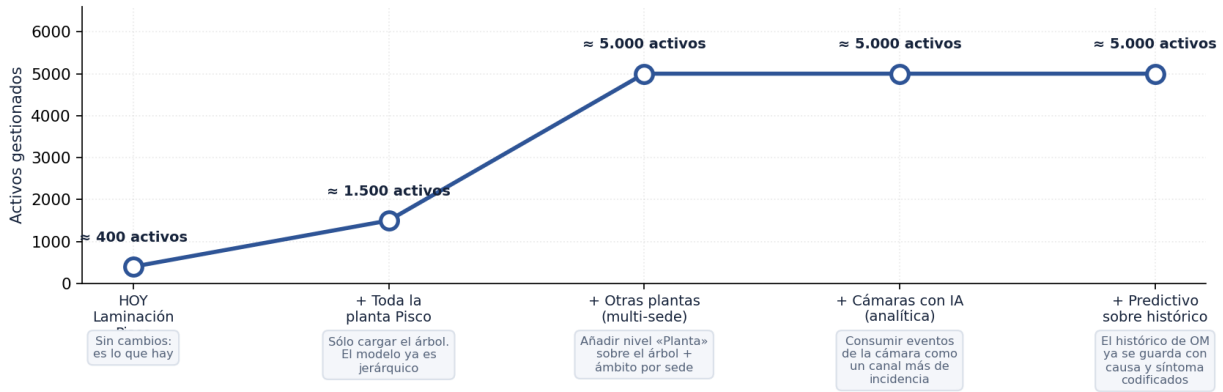


Figura 11 — Los cinco saltos de crecimiento y qué hace falta en cada uno.

9.1 De Laminación a toda la planta

Es el salto más barato y no requiere programar nada. El modelo de ubicaciones ya es un árbol de profundidad libre: añadir Acería, Trefilería o los patios es cargar más ramas. Todo lo que se deriva de la posición —tren, ambiente, criticidad, intervalo preventivo— seguirá funcionando igual.

9.2 De una planta a varias

Requiere añadir un nivel «Planta» por encima del árbol actual y extender el ámbito de los roles para que además del tren contemple la sede. La estructura está preparada; es trabajo acotado, no un rediseño.

9.3 Cámaras con analítica de vídeo

Éste es el salto que más valor aporta y el que más se está adoptando en el sector. La analítica basada en visión por computador aplicada a plantas siderúrgicas cubre hoy cuatro familias de uso maduras:

Aplicación	Qué detecta	Para qué sirve en Pisco
Equipo de protección personal	Casco, gafas, guantes, botas, arnés en trabajos en altura.	Cumplimiento automático y documentado. Los estudios del sector reportan reducciones de incidentes registrables de entre el 25 % y el 40 % frente a la observación manual.
Intrusión en zona caliente	Presencia de personas en áreas de barra caliente, rodillos o bajo carga suspendida.	Aviso inmediato en vez de reconstrucción posterior. Enlaza directamente con la clasificación de intervención por zona que el sistema ya tiene.
Proximidad a grúa puente	Personas bajo la carga o dentro del radio de maniobra.	Es uno de los riesgos con consecuencias más graves y peor cubierto por la observación humana.
Anomalía térmica y de llama	Patrones anómalos en hornos de recalentamiento mediante vídeo térmico.	Detección temprana de desviaciones de proceso. Hay trabajo publicado y revisado sobre sistemas híbridos de visión aplicados exactamente a este caso.

Qué hace falta en el sistema para soportarlo

Menos de lo que parece, y ésta es la ventaja de haber construido primero la base. El sistema ya tiene un modelo de incidencia con canal de origen —hoy distingue si el aviso vino de Producción, del técnico, del agente de monitoreo o del propio sistema—. Una cámara con analítica es simplemente un canal más: genera un evento, el evento entra como incidencia, y todo el flujo posterior —prioridad por criticidad de zona, detección de reincidencia, aviso al Jefe, orden de trabajo, cierre firmado— ya está construido y probado.

El orden importa. Poner analítica encima de una planta sin inventario produce alertas sobre equipos que nadie sabe dónde están. Poner analítica encima de este sistema produce órdenes de trabajo trazables. La base es lo que convierte una alerta en una acción.

9.4 Mantenimiento predictivo

El sistema ya guarda cada intervención con síntoma, causa y acción tomados de un catálogo cerrado, no en texto libre. Ésa es exactamente la materia prima que necesita un modelo predictivo: sin codificación, el histórico es un montón de frases y no se puede aprender de él. La decisión de usar catálogo en vez de texto libre se tomó por otro motivo —poder contar qué falla más— y resulta que además deja la puerta abierta a esto.

9.5 Mejoras de seguridad ya decididas

Verificación en dos pasos por correo

Al iniciar sesión, además de la contraseña, se enviará un código de un solo uso al correo corporativo. Con esto, una contraseña filtrada deja de ser suficiente para entrar. Es la medida de mayor relación entre protección obtenida y esfuerzo, y es el complemento natural del hallazgo S-01.

Aviso por correo al dar de alta a una persona

Cuando se cree una cuenta, la persona recibirá un correo indicando qué perfil se le ha asignado y a qué tren. Tiene dos efectos: la persona sabe qué se espera de ella, y cualquier alta que no debería haberse producido se detecta el mismo día en vez de en la próxima auditoría.

Ninguna de estas dos funciones está construida todavía. Se documentan aquí como compromiso, no como capacidad existente. El principio que rige todo este documento es que un modelo de datos y un endpoint no son una funcionalidad hasta que hay una pantalla que la use.

10. Lo que falta y lo que se pide a Producción

10.1 Infraestructura pendiente

El sistema puede gestionar más de lo que hoy hay declarado. Estas son las carencias de infraestructura, no de software:

Qué falta	Consecuencia hoy	Quién lo resuelve
Segmentación de la red por tren	Un único segmento plano: el radio de daño de cualquier intrusión es la planta entera.	TI / Redes
Rotulado físico normalizado en todos los equipos	Sin etiqueta no hay código que escanear, y el equipo es invisible para el sistema.	Mantenimiento CCTV
Códigos QR pegados en gabinetes y tableros	La ficha existe pero no tiene puerta de entrada desde el campo.	Mantenimiento CCTV
Declaración de cómo se interviene cada zona	Mientras no esté firmada, el sistema pide parada de tren. Es lo seguro, pero frena trabajo que podría hacerse en marcha.	Producción + SSOMA + Mantenimiento
Declaración de qué zonas son vitales	Sin ella todas las zonas pesan igual y la priorización de averías es plana.	Producción (Jefe de Tren)
Capacidad declarada de los grabadores	El sistema NO inventa cuántos canales libres quedan. Si el dato no está, no dice nada.	TI / Redes
Enlaces de red declarados	Sin ellos el mapa sale como cajas sueltas y el análisis de impacto no puede calcularse.	TI / Redes

10.2 Lo que se pide a Producción

Hay una parte del sistema que Mantenimiento no puede rellenar por sí solo, porque el conocimiento no está en Mantenimiento. Son tres cosas:

- Decir qué zonas no pueden quedarse a ciegas, y por qué. No es una opinión sobre cámaras: es una afirmación sobre el proceso productivo. Es la única escritura fuerte que tiene el Jefe de Tren en el sistema.
- Firmar cómo se interviene cada zona: en marcha, con permiso eléctrico, con permiso de altura, o con el tren parado. Esa firma queda con nombre y fecha, y es lo que permite que el sistema deje de pedir parada por defecto.
- Corregir el sistema cuando se equivoque. Si el sistema clasifica una zona como menos crítica de lo que es, eso se cambia desde la interfaz, sin tocar código y sin esperar a nadie.

Y la puerta está abierta

Todo lo relativo a planta —causas de falla, síntomas, acciones, rutinas preventivas, criticidad de zonas, cómo se interviene cada sitio— es editable desde la interfaz por diseño. Si hay que tocar código para cambiar una causa de fallo, está mal hecho. Cualquier sugerencia de Producción sobre cómo debería funcionar un proceso es bienvenida y, en la mayoría de los casos, se puede aplicar el mismo día.

10.3 Conclusión

El sistema no resuelve por sí solo el mantenimiento de la videovigilancia de Laminación. Lo que hace es convertir un proceso que vivía en la memoria de las personas, en cuadernos y en hojas de cálculo, en algo que se puede medir, auditar y mejorar.

El valor inmediato es que ahora existen datos donde antes había ceros: cuándo se cayó una cámara, cuánto se tardó en repararla, qué falla más, qué se queda sin ver si se apaga un switch, y quién autorizó trabajar en una zona caliente. El valor a medio plazo es que esos mismos datos son la base sobre la que se apoya cualquier paso siguiente —analítica de vídeo, mantenimiento predictivo, indicadores de gestión—.

Y el valor que no se ve en ningún indicador: un técnico que escanea un código en un poste, de noche, y antes de subir lee en rojo que esa zona exige que el tren esté parado.

Anexo A · Referencias consultadas

Fuentes externas utilizadas para las secciones de seguridad, analítica de vídeo y métricas de mantenimiento:

- CVE-2026-0709 — Vulnerabilidad de ejecución remota de comandos en puntos de acceso inalámbricos Hikvision. Puntuación CVSS v3.1: 7,2 (alta). Requiere credencial válida. Corregida en la versión de firmware V1.1.6601 build 251223.
- ISA/IEC 62443 — Norma internacional de ciberseguridad para sistemas de automatización y control industrial. Modelo de zonas y conductos aplicado en la sección 5.1.
- NIST SP 800-82 — Guía de seguridad para sistemas de control industrial.
- ISO 14224 — Recopilación e intercambio de datos de fiabilidad y mantenimiento de equipos. Base de la separación entre modo, mecanismo y causa de fallo.
- EN 13306 — Terminología del mantenimiento.
- ISO 55001 — Sistemas de gestión de activos.
- ANSI/TIA-606-C — Norma de administración de infraestructura de telecomunicaciones. Base del estándar de rotulado.
- Ley 29783 de Seguridad y Salud en el Trabajo (Perú) y norma G.050 — trabajos en altura a partir de 1,80 m.
- Departamento de Energía de Estados Unidos, Federal Energy Management Program — reducción del 25 % al 30 % en paradas no planificadas al sustituir mantenimiento reactivo por un sistema de gestión.
- McKinsey, investigación sobre Industria 4.0 — mejoras de disponibilidad del 20 % al 50 % en despliegues que combinan gestión de mantenimiento e instrumentación.
- Estudios de sector sobre analítica de vídeo con inteligencia artificial en siderurgia — reducción de incidentes registrables del 25 % al 40 % frente a observación manual; mercado de IA en acero valorado en 1.800 millones de dólares en 2024 con proyección superior a 6.400 millones en 2030.
- Trabajo revisado sobre monitorización de llama y detección de anomalías en hornos de recalentamiento siderúrgicos mediante vídeo térmico y visión artificial híbrida (PubMed Central, 2025).

Las cifras de mejora citadas corresponden a referencias del sector y NO constituyen una previsión de resultados para Planta Pisco. El sistema todavía no ha medido un ciclo completo. Se incluyen únicamente para situar el orden de magnitud del problema que se aborda.